

India's DPDPA readiness whitepaper 2026-2027

A practical guide for Indian businesses to prepare for notice, consent, security, rights, vendors, children's data, breach response, and sector-specific risk.

Privacy assessment

OPERATE framework

12 industry snapshots

CONTENTS

1. Cover
2. Who this whitepaper is for
3. Executive summary
4. CEO and board priority page
5. Legal status snapshot
6. Why DPDPA matters in 2026-2027
7. What the Act covers
8. Lawful processing
9. Core obligations
10. OPERATE model v6.1
11. Observe personal data
12. Permission and lawful basis
13. Evidence and records
14. Rights and grievance
15. Accountability and governance
16. Third-party and vendor control
17. Event and breach readiness
18. Implementation kits
19. 12 industry risk snapshots
20. Act section map
21. Court cases tracker
22. Open items to track
23. 90-day action plan
24. Disclaimer and product bridge
25. Glossary
26. Source register

Section 1: Cover

India's Digital Personal Data Protection Act is no longer a future law on a shelf. Rules are notified, the Data Protection Board of India is being constituted, and operational compliance dates sit on the calendar for 2026 and 2027. This whitepaper translates that legal machinery into decisions founders, boards, and operators can act on this quarter.

What you will find here:

- A plain-English map of what the Act requires and what is still open law
- The SaralPrivacy **OPERATE v6.1** framework: seven business capabilities, not seven legal chapters
- Implementation kits, industry risk snapshots, and a 90-day action plan
- A legal appendix with Act and Rules tables, case watchlist, glossary, and sources

Legal status one-liner (14 June 2026): Core operational duties under Sections 3-17 and most Rules take effect on **13 May 2027** unless Gazette amendments accelerate the timeline; Consent Manager duties begin **13 November 2026**. Treat any shorter deadline as **proposed until notified**.

Section 2: Who This Whitepaper Is For

WHO THIS IS FOR

- Founders and operators of Indian businesses that collect customer, employee, or vendor data digitally
- Compliance leads, CFOs, HR heads, and product managers who need plain-English guidance, not a law textbook
- Advisors (CAs, consultants, legal ops) who help SMEs get DPDPA-ready before deadlines hit
- International teams serving Indian users who need India-specific mechanics, not a GDPR copy-paste
- Board members and CXOs who need a one-page risk view before approving budget and ownership

WHO THIS IS NOT FOR

- Lawyers seeking clause-by-clause commentary (use Sections 20-22 and the glossary instead)
- Organisations looking for a one-page checkbox without operational change
- Readers who want certainty on rules not yet notified (SDF list, restricted countries, Board portal details)

SECTORS WITH DEDICATED SNAPSHOTS IN SECTION 19

CA firms, recruitment agencies, training institutes, D2C brands, clinics and diagnostic labs, schools and colleges, law firms, real estate, hotels and travel, pharmacies, fintech and NBFCs, gyms, salons and spas.

Section 3: Executive Summary

Know your gaps. Fix what matters. Signal trust.

India's DPDPA changes how businesses treat personal data from first collection to breach response. The Act does not ban data use. It requires **lawful purpose, clear notice, defensible consent or narrow legitimate use, reasonable security, timely breach response, working rights channels, and processor control** - with evidence that each control exists. For most Indian operators, the shift is from informal habits (WhatsApp intake, shared folders, bundled consents, indefinite retention) to **documented, owned programmes** that survive a regulator or enterprise customer asking "show me."

Why CEOs should care now. Three clocks are running: the Board is live; Consent Manager infrastructure becomes real from November 2026; operational compliance is scheduled for May 2027 but may accelerate if MeitY shortens the runway. Penalties reach Rs 250 crore in tiered ceilings, but the nearer-term risk is **trust, procurement, and litigation shape** - partners and customers already ask for data maps and breach playbooks. Waiting until the final Gazette date means rebuilding under pressure.

Five things to start this quarter:

1. **Name one accountable owner** for DPDPA readiness (not a committee without a driver).
2. **Build a processing activity register** - what data, why, where, who accesses it, how long it stays.
3. **Fix standalone notices** at major collection points; separate optional marketing consent.
4. **Upgrade processor contracts** and map cross-border flows.

5. **Run a breach tabletop** and open a rights/grievance inbox with a 90-day SLA tracker.

What remains open law. Restricted-country lists, Significant Data Fiduciary designations, specified localisation categories, Consent Manager operational details, and timeline compression are **watch items** until Gazette confirmation. This whitepaper labels each item as in force, notified phase, proposed, or pending litigation - never merged.

How to read the rest of this document. Sections 5-9 give legal foundation. Sections 10-17 walk OPERATE v6.1 chapter by chapter. Section 18 provides kits; Section 19 shows where risk concentrates by industry. Sections 20-22 are legal appendix material. Section 23 is your 90-day starter plan. Section 24 explains scope and how SaralPrivacy tools fit without replacing counsel.

Bottom line for leadership: DPDPA readiness is an operating capability - inventory, permission, proof, rights, governance, vendors, and incident response - not a policy PDF. Organisations that build evidence in 2026 will negotiate partnerships, handle complaints, and face regulatory questions from a position of clarity. Those that wait for a final headline date risk rebuilding under pressure.

Section 4: CEO and Board Priority Page

Boards do not need to read the entire Act. They need five decisions, five risks, five evidence items, and clarity on what **not** to overbuild before the law settles.

FIVE LEADERSHIP DECISIONS

1. **Name a single accountable owner** - product, legal, or ops - with board visibility, not "everyone owns privacy."
2. **Decide which processing is consent vs legitimate use** and document the call; do not assume all HR or KYC flows are exempt.
3. **Approve a vendor and cross-border review this quarter** - cloud, payroll, CRM, ad-tech, BGV, payment partners.
4. **Set a breach escalation path before an incident** - legal, security, communications, and Board notification roles.
5. **Choose two industry-specific flows to fix first** (from Section 19) where your real data leaks today.

FIVE OPERATIONAL RISKS

1. **WhatsApp and personal phones** as default channels for PAN, health, prescriptions, CVs, or guest IDs.

2. **Shared cloud folders and stale access** - ex-staff, interns, freelancers, old broker partners.
3. **Marketing and analytics without separate consent** - pixels, cart campaigns, WhatsApp promos.
4. **Indefinite retention** of old customer, candidate, patient, or employee records.
5. **Processors used without contracts** or without security and breach-cooperation clauses.

FIVE EVIDENCE ITEMS TO MAINTAIN

1. Processing activity register (dated, owned, reviewed quarterly).
2. Notice and consent version log (what users saw, when, on which channel).
3. Processor and vendor contract register with DPDPA-aligned clauses.
4. Rights and grievance request log with closure dates.
5. Breach and incident record - including tabletop drills.

FIVE THINGS NOT TO OVERBUILD YET

1. Full Significant Data Fiduciary programme before designation criteria and lists are final.
2. Consent Manager integration before the November 2026 framework is operational in your sector.
3. Country-level transfer blocklists before government notifications publish.
4. Enterprise GRC platform before basic inventory, notices, and vendor contracts exist.
5. Claiming "fully compliant" while litigation and phase dates are still moving.

EVIDENCE PACK AT A GLANCE

Diagram: see figure below.



EVIDENCE PACK CHECKLIST

Maintain these records to demonstrate compliance with the DPDPA, 2023.



1  PROCESSING REGISTER Record of personal data processing activities, purposes, legal basis, data categories, recipients, and safeguards. ☐	2  NOTICE LOG Copies of privacy notices issued and records of updates with effective dates. ☐	3  VENDOR CONTRACTS Contracts and DPAs with processors and third parties including data protection obligations. ☐	4  RIGHTS LOG Records of data principal requests, actions taken, responses, and timelines met. ☐
5  BREACH RECORDS Records of personal data breaches, impact assessment, notifications, and remediation measures. ☐	6  ACCESS REVIEWS Periodic access reviews and certifications for systems and personal data. ☐	7  RETENTION SCHEDULE Data retention periods by category and rules for secure deletion or anonymization. ☐	8  POLICY TRACKER Records of privacy policies, procedures, versions, approvals, and review dates. ☐



Be Prepared. Be Accountable. Be Compliant.
Keep your evidence pack up-to-date and audit-ready.

#DPDPAinPractice

Figure: Infographic 8: Evidence Pack Checklist (PNG export for PDF; Mermaid source in [infographics/](#))

#	Evidence item	Owner	Review cadence
1	Processing activity register	Ops / Product	Quarterly
2	Notice and consent versions	Legal / Product	On every change
3	Vendor contracts with DPDPA clauses	Procurement / Legal	On onboarding
4	Rights and grievance log	Support / Legal	Monthly
5	Breach and incident log	Security / Legal	After every event + annual drill
6	Access review records	IT / HR	Quarterly
7	Retention schedule + deletion proof	Ops / IT	Semi-annual
8	Regulatory watch log	Compliance	Monthly

CEO takeaway: Compliance is proven with **records**, not intentions.

Section 5: Legal Status Snapshot (June 2026)

Area	Current legal position	Practical consequence
In force now	Section 1(2), Section 2, Sections 18-26, 35, 38-43, and Section 44(1),(3); Rules 1, 2, 17-21.	Definitions, DPBI constitution, rule-making, certain amendments and Board framework are active.
13 Nov 2026	Section 6(9) and Section 27(1)(d); Rule 4.	Consent Manager framework and related duties begin.
13 May 2027	Sections 3-17, most of Section 6, Sections 27-34, 36, 37, Section 44(2); Rules 3, 5-16, 22, 23.	Operational readiness deadline for notice, consent, breach, rights, children, retention, SDF, appeals and government information powers.
Not yet clear	Restricted country list, SDF designations, specified SDF localisation data categories, Board portal procedures in practice.	Track MeitY/DPBI notifications before making absolute claims.
Enforcement readiness	DPBI establishment notified; digital proceedings framework in Rules 17-21; phased operational dates.	Build evidence packs now - enforcement infrastructure is forming before operational deadlines.

POLICY HORIZON ALERT

Treat the items below as watch items until a Gazette amendment confirms them. They are proposed or discussed - not notified law as of 14 June 2026.

Signal	What was discussed	Business impact
Jan 2026 stakeholder meeting (reported)	Compress 18-month runway to 12 months; fast-track SDF list; Rule 8(3) retention within 90 days post-amendment	Operational deadline may move from 13 May 2027 toward 13 Nov 2026
Feb 2026 (reported)	Industry feedback window on timeline compression	Outcome pending Gazette
Jun 2026 (reported, ET Telecom)	MeitY Secretary awaiting industry input on timeline	No final call yet - do not plan on an accelerated date as law

Signal	What was discussed	Business impact
Karnataka (reported, 2026)	Social media ban proposal for under-16	National vs state competence unclear - policy debate only
Pending litigation	Supreme Court / Delhi HC challenges on RTI interface, exemptions, Board structure	Awareness only - Act not stayed as of this date

Author rule: Always label items as **in force**, **notified phase**, **proposed**, or **pending litigation**. Never merge them.

NUMBERS STRIP

18 months	4+1 rights	72 hr	90 days	Rs 250 Cr
Phased compliance window from Rules notification (13 Nov 2025)	Access, correction, erasure, grievance, plus nomination	Detailed breach report to DPBI after notification (Rule 7)	Maximum grievance response time (Rule 14)	Tiered maximum penalty ceiling under the Act

Section 6: Why DPDPA Matters in 2026-2027

INDIA'S DIGITAL STACK - PRIVACY AS THE TRUST LAYER

India built a digital public infrastructure that most countries only talk about: identity (Aadhaar), payments (UPI), documents (DigiLocker), and consent rails (Account Aggregator). Think of it like a modern highway system - fast lanes for commerce, toll plazas for verification, and millions of vehicles (apps and businesses) on the road.

Until recently, the highway had speed limits but no uniform traffic police for personal data. The DPDPA is that traffic system: it tells businesses **what data they may carry, how they must protect it, and what happens when they crash**.

Analogy for non-technical readers: Your shop has always kept a customer register. DPDPA asks you to (1) tell customers what you write in the register, (2) only write what you need, (3) lock the register, (4) let customers see or erase their page, and (5) call the authorities quickly if the register is stolen. The register did not become illegal - careless handling did.

CONSENT ALONE IS NOT ENOUGH

Many teams hear "DPDPA" and jump straight to consent banners. Consent is necessary for many flows, but the Act also demands **security, breach notification, retention discipline, rights handling, processor contracts, and accountability evidence**. A business with perfect consent logs but shared WhatsApp folders, no breach playbook, and indefinite CV storage is still exposed. OPERATE v6.1 separates **Permission** (lawful basis) from **Evidence** (proof) and **Accountability** (governance) for this reason.

UNIVERSAL PRIVACY PRINCIPLES (OECD / APEC BASELINE)

Across 160+ jurisdictions, the same themes repeat. India aligns with these even where mechanics differ:

- 1. **Transparency** - tell people what you collect and why
- 2. **Purpose limitation** - use data only for the stated reason
- 3. **Data minimisation** - collect the smallest amount that works
- 4. **Security** - protect data with reasonable safeguards
- 5. **Individual rights** - access, correction, deletion, complaint routes
- 6. **Accountability** - prove you did the above, especially under a digital regulator
- 7. **Cross-border responsibility** - know where data travels and who answers for it

The DPDPA is India's version of these habits, not a foreign import with Indian letterhead.

GLOBAL COMPARISON - BUSINESS LENS

Dimension	GDPR (EU/UK)	CCPA/CPRA (US)	LGPD (Brazil)	DPDPA (India)	Business takeaway
Philosophy	Rights-first	Consumer opt-out / notice	Rights + legitimate interest	Execution-first, trust-at-scale	India rewards built systems , not paper policies
Lawful processing	6 bases (Art 6)	Notice + opt-out; limited bases	10 legal bases	Consent or narrow Section 7 legitimate uses	Fewer non-consent routes than GDPR - do not stretch Section 7
Consent standard	Freely given, specific, informed	Opt-out for sale/share; opt-in for minors	Similar to GDPR	Free, specific, informed, unconditional, unambiguous	Pre-ticked boxes fail everywhere; India is explicit

Dimension	GDPR (EU/UK)	CCPA/CPRA (US)	LGPD (Brazil)	DPDPA (India)	Business takeaway
Sensitive data	Special categories (Art 9)	Sensitive PI under CPRA	Sensitive data	No separate category - but type still drives risk, penalties, SDF	Treat health, biometric, children's data as high-care , not "non-sensitive"
Children	13-16 tiered (member state)	Under 16 opt-in	Parental consent	Uniform under 18	Stricter single threshold
Cross-border	SCCs, adequacy, TIA	Sector/state patchwork	ANPD guidance	Permissive default; government may restrict list + Rule 15	Map flows; monitor MeitY notifications
Regulator	National DPAs	AG + CPPA	ANPD	DPBI (digital-first)	Evidence packs matter
Unique feature	DPO mandate (some controllers)	Do Not Sell/Share	DPO-like roles	Consent Manager (registered intermediary)	India-only infrastructure play
Max penalty	EUR 20M / 4% turnover	\$7,500/violation (varies)	2% revenue / 50M BRL	Rs 250 Cr ceilings (tiered)	Prioritise security + breach notification
Enforcement style	Mature, high volume	Growing, fragmented	Growing	Phased - Board live; ops dates 2026-2027	Start now; dates may accelerate

INDIA VS GDPR - MYTHS VS FACTS

Myth	Fact (DPDPA)
"GDPR compliant = DPDPA ready"	Different lawful bases, no SCC regime, Consent Manager, phased commencement

Myth	Fact (DPDPA)
"No sensitive category = low risk health data"	Health/children/financial data still attract scrutiny and sector rules
"We have until May 2027"	MeitY discussing 12-month acceleration; SDF/cross-border may move faster
"Breach always means Rs 250 Cr fine"	Penalty tied to failure to implement reasonable security safeguards (Sec 8(5))
"One privacy policy is enough"	Rule 3: notice must be independently understandable at each collection point

WHY 2026 IS THE REAL START LINE

Three clocks are running at once:

1. **Board clock (live):** DPBI exists. Evidence-led digital enforcement is being built now.
2. **Consent Manager clock (13 Nov 2026):** Registered intermediaries and integrations become real.
3. **Operations clock (13 May 2027, possibly sooner):** Notice, consent, security, breach, rights, children, processors - the work most businesses feel.

2026 is when programmes must shift from "we will hire someone later" to "we can show our data map and breach playbook today." The businesses that treat privacy as customer trust - not a legal footer - will move faster when procurement, partnerships, and regulators ask for proof.

Section 7: What the Act Covers

Before building controls, leaders need a shared vocabulary. DPDPA uses defined roles and a digital-first scope. This section is the plain-English map.

KEY DEFINITIONS

Term	Who / what	Plain meaning
Digital personal data	The data itself	Personal data in digital form, plus offline personal data that is later digitised

Term	Who / what	Plain meaning
Data Principal (DP)	The person	Customer, employee, student, patient, guest, candidate - anyone whose data you process
Data Fiduciary (DF)	Usually your company	The entity that decides why and how personal data is processed
Data Processor	Vendors	Cloud host, payroll SaaS, ATS, payment gateway, analytics tool - processes data on your instruction
Consent Manager (CM)	Registered intermediary	India-specific layer helping people give, manage, and withdraw consent across services (from Nov 2026)
Significant Data Fiduciary (SDF)	Notified large/high-risk DF	Extra duties: DPIA, audit, algorithmic diligence, possible localisation - only if government designates you

APPLICABILITY - WHEN THE ACT TOUCHES YOUR BUSINESS

Section 3 applies when you process digital personal data:

- **In India** - customers, employees, vendors, website users
- **Offline data later digitised** - paper forms scanned into a system
- **Outside India** - if processing connects to offering goods or services to people in India

Exclusions and carve-outs exist (Section 17 and Rule schedules) for certain State, research, legal, and security contexts. Do not self-certify broad exemptions without counsel. Examples that sometimes confuse teams: processing strictly necessary for a legal claim, certain court-directed disclosures, and research/statistics that meet Rule 16 standards without individual decisioning. Even where an exemption may apply, **documentation** of the legal basis and narrow scope still matters for accountability.

PERSONAL DATA IN PRACTICE - WHAT TEAMS FORGET TO COUNT

Operators often under-count personal data because it hides in operational tools rather than customer databases. Common overlooked sources include: recruiter Excel trackers, WhatsApp Business chat exports, CCTV footage with identifiable individuals, attendance and GPS logs, employee monitoring on work devices, old backup tapes, test environments with production copies, and AI training sets built from customer support tickets. Observe means counting these honestly, not only CRM rows.

Unlike GDPR, India does not label a statutory special category. That does **not** mean health, financial, children's, or biometric data is low risk. Sector rules, SDF scrutiny, and customer trust still treat these as **high-care** data requiring stronger notice, security, retention, and rights handling.

ROLE ECOSYSTEM

Diagram: see figure below.

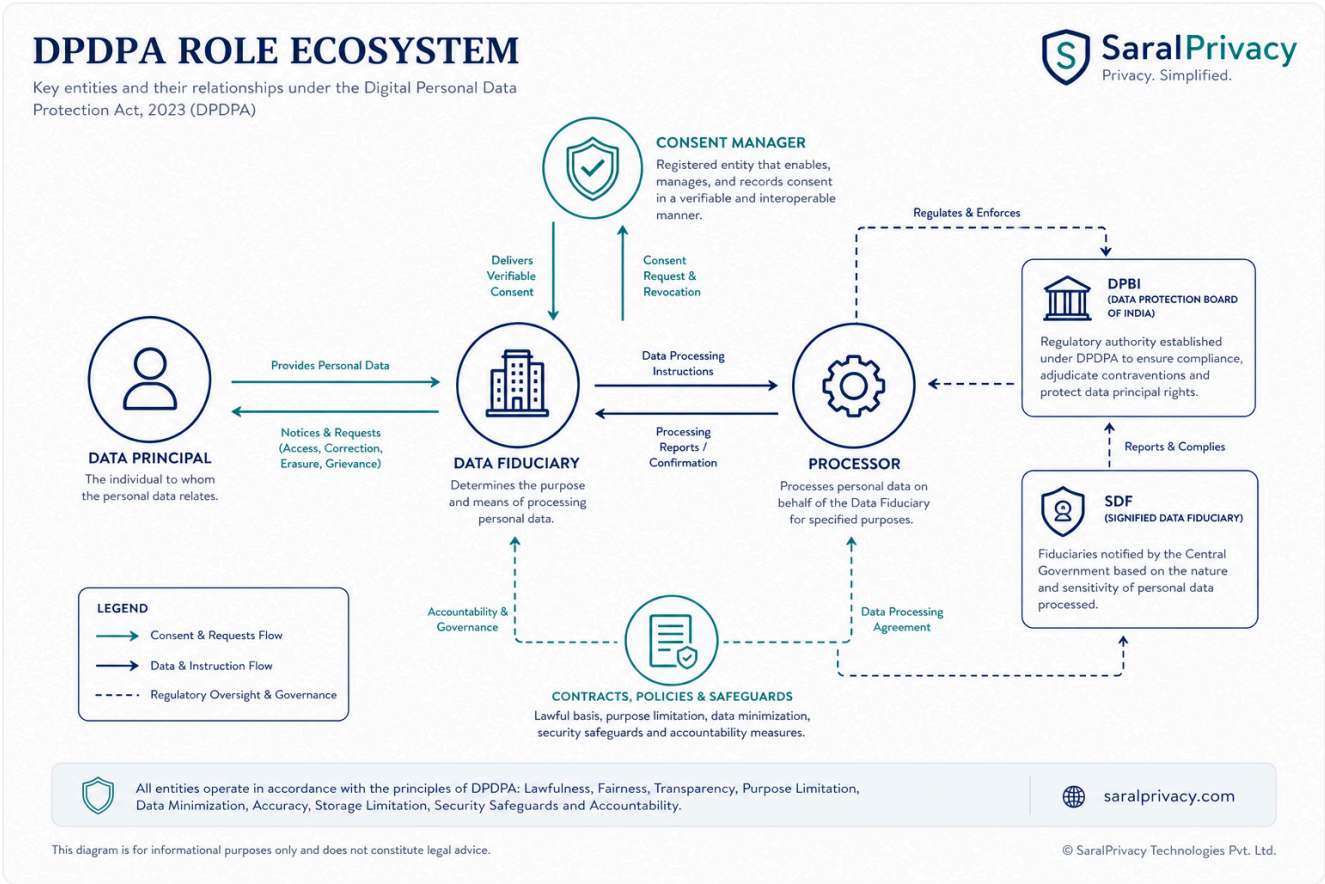


Figure: Infographic 1: DPDPA Role Ecosystem (PNG export for PDF; Mermaid source in infographics/)

Plain English: The business is usually the **Data Fiduciary**. Your vendors are **Processors**. The person is the **Data Principal**. Consent Managers are an India-only layer. SDF applies only if government notifies your organisation.

Section 8: Lawful Processing - Consent and Legitimate Uses

Every collection and use needs a lawful route: **consent** under Section 6 or a narrow **legitimate use** under Section 7. This section rolls up the legal foundation before OPERATE chapters go operational.

CONSENT REQUIREMENTS (SECTION 6)

Consent must be:

- **Free** - no denial of core service for refusing optional processing
- **Specific** - marketing, analytics, photos, and referrals separated from core delivery
- **Informed** - backed by standalone notice (Section 5, Rule 3)
- **Unconditional** - not bundled with unrelated terms
- **Unambiguous** - clear affirmative action; no pre-ticked boxes
- **Withdrawable** - at least as easy as giving consent

Children (Section 9): Uniform threshold **under 18**. Verifiable parental consent; no tracking, behavioural monitoring, or targeted advertising directed at children.

LEGITIMATE USES (SECTION 7) - NARROW LIST, NOT A CONVENIENCE HATCH

Examples include voluntary data provided by the Data Principal for a specified purpose, State functions, compliance with law, court orders, medical emergency, disaster/public order, and certain employment safeguards. **Do not map GDPR "legitimate interests" directly to Section 7.** When uncertain, use notice plus consent and document the decision.

NOTICE ALIGNMENT (SECTION 5, RULE 3)

Notice must be **independently understandable**, plain, itemised, and available at the collection point - not buried in Terms and Conditions. It must explain data collected, purpose, rights, withdrawal, grievance contact, and Board complaint route.

CONSENT AND LEGITIMATE-USE DECISION FLOW

Diagram: see figure below.

CONSENT vs LEGITIMATE USE

Decision Flowchart under DPDPA, India

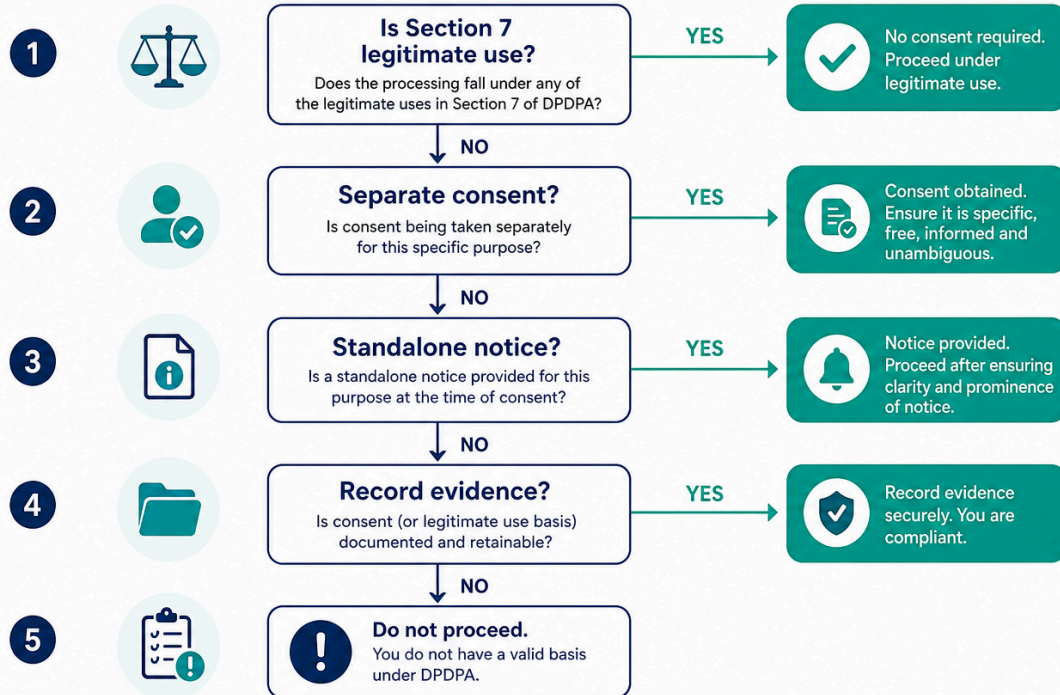


Figure: Infographic 2: Consent and Legitimate-Use Flow (PNG export for PDF; Mermaid source in [infographics/](#))

Decision rule: Do not default every business convenience to legitimate use. When in doubt, use **notice + consent** and keep evidence.

EMPLOYMENT, STATE, AND LEGAL CONTEXTS

HR payroll, attendance, and statutory filings often fit legitimate-use or contractual necessity patterns - but still need notice, security, retention limits, and rights channels. Government-linked benefit programmes must review Schedule 2 standards. Legal proceedings and regulatory requests need documented legal basis and escalation to counsel.

Section 9: Core Obligations Under DPDPA

This table maps statutory duties to OPERATE v6.1 and the evidence leaders should expect.

Obligation	Act / Rule anchor	OPERATE letter	Evidence type
Know your data	Sec 3, 8; Rule 6	Observe	Processing activity register, flow map
Lawful basis	Sec 4, 6, 7	Permission	Basis tags, consent logs, Section 7 memos
Notice	Sec 5; Rule 3	Permission	Dated notices per channel, change log
Consent / withdrawal	Sec 6	Permission	Timestamped consent, withdrawal records
Security safeguards	Sec 8(5); Rule 6	Event (prevent) + Accountability	Security baseline, access reviews, logs
Breach notification	Sec 8(6)-(7); Rule 7	Event	Incident timeline, user/Board notices, 72-hour report
Retention / erasure	Sec 8(7); Rule 8	Evidence + Event	Retention schedule, deletion proof
Rights + grievance	Sec 11-14; Rule 14	Rights	Request register, SLA tracker, closures
Children's data	Sec 9; Rules 10-12	Permission + kits	Age gate, parental consent, no child ads
Processor control	Sec 8; Rule 6	Third-party	Contracts, vendor register, audits
Cross-border transfer	Sec 16; Rule 15	Third-party	Transfer map, restriction watch log
Governance / contact	Rule 9; Sec 10 (SDF)	Accountability	Named owner, DPO contact, board reviews
Programme proof	Sec 8 accountability	Evidence	Full evidence pack (Section 4, 13)

Leadership read: If you cannot point to the evidence column for a row, assume the obligation is not operating yet.

HOW OBLIGATIONS INTERACT IN REAL OPERATIONS

Few businesses fail on a single missing checkbox. Failure patterns are usually **compound**: WhatsApp intake without notice, plus indefinite retention, plus no breach playbook, plus vendor without contract. The table above is a diagnostic grid. When auditing a flow - for example clinic report sharing or fintech KYC - walk the row top to bottom and mark which evidence exists today. That compound view is what DPBI proceedings and enterprise procurement diligence increasingly resemble.

Section 10: The SaralPrivacy OPERATE Model (v6.1)

The SaralPrivacy **OPERATE** model turns DPDPA from statute sections into seven business capabilities. v6.1 reframes letters to match how operators actually build programmes: observe data, earn permission, keep evidence, honour rights, show accountability, control third parties, and rehearse events (especially breaches).

O	OBSERVE	– Know what data you have and where it flows
P	PERMISSION	– Lawful basis, notice, consent, legitimate use
E	EVIDENCE	– Logs, contracts, versions, proof packs
R	RIGHTS	– Access, correction, erasure, grievance, nomination
A	ACCOUNTABILITY	– Owners, policies, training, board reporting
T	THIRD-PARTY	– Processors, vendors, cross-border
E	EVENT	– Breach detection, 72-hour clock, escalation

Diagram: see figure below.

OPERATE

A Privacy-by-Design Framework for DPDPA Compliance

The OPERATE framework helps organisations operationalise privacy obligations under the DPDPA, 2023 through seven foundational pillars.

Privacy is not an event.
It's how you **OPERATE**.



Figure: Infographic 3: OPERATE v6.1 Model (PNG export for PDF; Mermaid source in [infographics/](#))

Letter	Question every leader should ask
O	What data do we actually collect and where does it live?
P	Why are we allowed to use it - consent or legitimate use?
E	Can we prove notices, consents, and contracts?
R	Can people access, correct, erase, and complain easily?
A	Who owns this programme and when was it last reviewed?
T	Are vendors and processors under contract and control?
E	What happens in the first 72 hours after a leak?

Each chapter below uses the same six-block recipe: hook, outcomes, actions, India anchors, GDPR comparison, evidence checklist.

Section 11: OPERATE Chapter 1 - Observe Personal Data

1. Business hook

You cannot protect what you cannot name. Most DPDPA failures start the same way: leadership thinks the company holds "basic customer info," while engineers, HR, and vendors quietly hold PAN copies, health records, and years of WhatsApp exports. **Observe** means building a living map of personal data - like inventory in a warehouse, not a one-time Excel dump.

Analogy: DPDPA readiness is like preparing for a tax audit. You do not wait for the notice to discover which drawers hold old receipts. You label drawers now.

2. What good looks like

- A processing activity register (PAR) listing **what** data, **why**, **who** accesses it, **where** it is stored, and **how long** it stays
- Owner named for each activity (marketing, HR, finance, product)
- Data flows documented for India and cross-border systems
- Red-flag flows flagged early: WhatsApp intake, shared drives, ex-employee access, shadow IT
- Updates triggered when you launch features, vendors, or new collection points

3. Do this now

1. List every place personal data enters your business: website forms, apps, WhatsApp, email, paper, CCTV, HR tools, payment gateways.
2. For each entry point, record data categories (name, phone, PAN, health, photos, location, etc.).
3. Mark each flow as customer, employee, vendor, or lead data with a business purpose tag.
4. Identify processors (cloud, payroll, ATS, CRM, ad-tech) and link them to activities.
5. Highlight high-care data even without a "sensitive" label: children, health, financial, biometric.
6. Assign an activity owner and review calendar (quarterly minimum).
7. Store the register where legal, security, and product can all access it.

4. India anchor box

Anchor	Requirement
Section 3	Act applies to digital personal data in India, offline data later digitised, and foreign processing tied to offering goods/services in India

Anchor	Requirement
Section 8	Data Fiduciary remains accountable for lawful processing and processor control
Rule 6	Security includes access control, logs, monitoring - you need to know who touched what

5. If you know GDPR

GDPR Article 30 requires Records of Processing Activities (ROPA) for many controllers. India's approach is similar in practice but not identical in form: build the same inventory habit, but tag lawful basis under **Section 4 + 6/7**, not GDPR Article 6 labels.

6. Evidence checklist

- ☐ Processing activity register (version dated)
- ☐ Data flow diagram or table (internal + cross-border)
- ☐ Processor/vendor list linked to activities
- ☐ High-care data classification notes
- ☐ Quarterly review log with named owner

Section 12: OPERATE Chapter 2 - Permission and Lawful Basis

Permission combines what v6 split across **Permit** and **Explain**: lawful basis discipline **and** notices people actually understand at the moment of collection.

1. Business hook

Collecting data is easy. **Being allowed** to use it is the law. Permission is your lawful-processing plus notice discipline: every use needs either **consent** or a narrow **Section 7 legitimate use** - not "we always did it this way." And users must understand what they agreed to **at the collection point**, not on page 47 of a policy PDF.

Analogy: Consent is like a guest list at a wedding. Legitimate use is like letting the caterer into the kitchen without a separate invitation - but only because they have a specific job, not because they wandered in. The notice on the invitation is what makes both legitimate.

2. What good looks like

- Every processing activity tagged: **consent** or **legitimate use** (with Section 7 subsection cited)

- Marketing, profiling, photos, referrals, and optional analytics on **separate consent**
- Consent records show what was agreed, when, and how withdrawal works
- No pre-ticked boxes; clear affirmative action
- Standalone notice at each collection point - not hidden inside Terms and Conditions
- Plain language, itemised: what data, why, rights, withdrawal, grievance contact, Board complaint route
- Consent Manager strategy documented if you integrate with registered intermediaries (from 13 Nov 2026)
- Children's flows use verifiable parental consent; no targeted ads to children

3. Do this now

1. Audit current consents: website, app, WhatsApp, paper forms, contracts - are they specific or bundled?
2. Split **necessary** processing (order fulfilment, payroll) from **optional** processing (ads, testimonials, talent pools).
3. Inventory every collection point: web, app, offline form, WhatsApp bot, reception desk.
4. Draft a **short notice template** (200-400 words) per major flow.
5. Remove core notice from T&Cs; link or embed notice separately.
6. Build a one-page **lawful processing decision tree** for product and sales teams.
7. Document Section 7 uses narrowly (employment safeguards, legal compliance, medical emergency - not "business convenience").
8. Implement easy withdrawal at least as easy as opt-in.
9. For under-18 users, block behavioural ads and tracking; plan parent verification (Rule 10).
10. Add withdrawal, rights request, and grievance paths with working contact details.

4. India anchor box

Anchor	Requirement
Section 4	Processing for lawful purpose with consent or legitimate uses
Section 5	Notice covers data, purpose, rights, withdrawal, complaint route
Section 6	Consent must be free, specific, informed, unconditional, unambiguous; easy withdrawal
Section 7	Limited non-consent grounds - do not expand by interpretation

Anchor	Requirement
Section 9	Children: verifiable parental consent; no tracking/behavioural ads directed at children
Rule 3	Independently understandable, plain, itemised; links for withdrawal, rights, Board complaint
Rule 4 + Schedule 1	Consent Manager requirements (from 13 Nov 2026)

5. If you know GDPR

GDPR offers six lawful bases and Articles 13/14 transparency. India offers essentially two routes and Rule 3 explicitly requires notices to be **independently understandable** – a direct strike against T&C bundling. **Do not map GDPR "legitimate interests" directly to Section 7.**

6. Evidence checklist

- ☐ Lawful basis tag per processing activity
- ☐ Consent logs (timestamp, scope, channel)
- ☐ Withdrawal mechanism screenshots or workflow
- ☐ Section 7 justification memos where used
- ☐ Notice copies per collection channel (dated versions)
- ☐ Screenshots of in-product notice placement
- ☐ Child-facing flow assessment and parent consent design
- ☐ Consent Manager integration plan (if applicable)

Section 13: OPERATE Chapter 3 - Evidence and Records

Evidence is the proof layer. DPBI proceedings are digital and document-led. When a customer complains, a vendor leaks, or a board asks "are we ready?", organisations win or lose on **records**, not intentions.

1. Business hook

Policies in slide decks do not survive scrutiny. **Evidence** means you can show what notice a user saw, what consent they gave, which contract governed a vendor, how a grievance closed, and

what happened hour-by-hour in a breach drill. Think of it like keeping invoices for GST - the law cares about proof of process.

Analogy: A pilot's logbook does not fly the plane, but no airline certifies a pilot without it. DPDPA evidence works the same way.

2. What good looks like

- Version-controlled notices and consent flows with timestamps
- Consent logs tied to notice version, channel, and scope
- Processor register with signed contracts and review dates
- Rights and grievance register with identity verification steps and closure proof
- Breach and incident log including tabletop exercises
- Retention schedule with deletion records and documented exceptions
- Security baseline documentation and quarterly access reviews
- Policy horizon log separating **notified** from **proposed** changes

3. Do this now

1. Create a single **evidence pack index** (see Section 4 infographic) with owners and review cadence.
2. Start a **notice and consent version log** - date, channel, screenshot or URL, approver.
3. Centralise **vendor contracts** with DPDPA security, breach, deletion, and audit clauses.
4. Open a **rights/grievance register** - ticket ID, date received, action, date closed.
5. Log **retention decisions** when data is deleted or extended past standard period.
6. File **breach drill records** like real incidents - timeline, roles, templates used.
7. Link evidence items to entries in your processing activity register.

4. India anchor box

Anchor	Requirement
Section 8	Data Fiduciary accountability for lawful processing and safeguards
Section 6	Ability to demonstrate consent and withdrawal
Rule 3	Notice content and accessibility must be provable at collection
Rule 6	Security measures and processor clauses must be documented

Anchor	Requirement
Rule 7	Breach facts, notifications, and 72-hour reports must be retained
Rule 14	Rights and grievance handling must be traceable within 90-day ceiling

5. If you know GDPR

GDPR accountability (Article 5(2)) and record-keeping mirror this chapter. India's phased commencement means many firms are building evidence **before** full enforcement - use the runway to avoid paper-only compliance.

6. Evidence checklist

- ☐ Evidence pack index with owners
- ☐ Notice and consent version log
- ☐ Consent and withdrawal records
- ☐ Processor contract register
- ☐ Rights/grievance register
- ☐ Breach/incident log (including drills)
- ☐ Retention schedule and deletion proof
- ☐ Security baseline and access review records
- ☐ Regulatory watch log

Section 14: OPERATE Chapter 4 - Rights and Grievance Handling

Privacy law is not only about stopping bad things. People must be able to **ask** - see their data, fix it, erase it, complain, and nominate someone to act for them. **Rights** is your customer service lane for data requests, with a **90-day grievance ceiling**.

1. Business hook

If a bank account holder cannot get a statement on request, the bank loses trust even without fraud. Data rights work the same way.

Analogy: Returns desks exist because commerce needs a fair correction path. Rights requests are that desk for personal data.

2. What good looks like

- Published channel for access, correction, erasure, grievance, and nomination requests
- Identity verification steps that are fair and documented
- Ticket queue with owner, SLA tracker, and closure evidence
- Grievance responses within **90 days maximum** (Rule 14)
- Fair-use language for Data Principal duties (no false complaints, no impersonation)
- Escalation path to DPBI documented in notice

3. Do this now

1. Publish "Exercise your rights" instructions on website/app with email or form.
2. Assign a grievance owner (need not be full-time DPO for all firms).
3. Create request templates: access, correction, erasure, nomination.
4. Define identity verification (proportionate to risk).
5. Track requests in a simple register with dates and outcomes.
6. Set internal SLA well under 90 days; escalate at day 60.
7. Train support staff not to dismiss requests as "IT only."

4. India anchor box

Anchor	Requirement
Sections 11-14	Access, correction, completion, updating, erasure, grievance, nomination
Section 15	Data Principal duties - fair use in your workflow
Rule 14	Publish request methods; grievance response within maximum 90 days

5. If you know GDPR

GDPR Chapter III rights are broader in case law volume but similar in shape. India's **90-day grievance cap** is a clear number - build ops to it, not to informal email threads.

6. Evidence checklist

- [] Published rights and grievance process
- [] Request register with timestamps
- [] Identity verification procedure
- [] Closed request samples (redacted)
- [] SLA dashboard or monthly report

- [] Nomination handling notes
-

Section 15: OPERATE Chapter 5 - Accountability and Governance

Accountability turns privacy from a project into a managed business function. Someone must own the programme, the board must see material risk, and staff must know the rules.

1. Business hook

Without governance, privacy becomes a annual policy PDF and a forgotten vendor spreadsheet.

Accountability names owners, sets review cadence, trains teams, and reports upward - the same way finance has a CFO and monthly closes.

Analogy: Workplace safety needs a fire marshal and drills, not just a poster. Privacy governance is that operating layer.

2. What good looks like

- Named DPDPA programme owner with executive sponsor
- Published DPO or authorised contact (Rule 9) on website, app, and notices
- Core policy set: privacy notice framework, retention, security baseline, vendor standard, rights SOP, breach playbook
- Onboarding and annual refresher training for staff who touch personal data
- Quarterly access reviews for high-care systems
- Board or leadership summary at least twice a year: top risks, open items, evidence maturity
- SDF readiness track only if designation is plausible

3. Do this now

1. Appoint a single accountable owner and document responsibilities.
2. Publish grievance/DPO contact in notices and website footer.
3. Approve a minimal policy set mapped to OPERATE letters.
4. Run a 60-minute DPDPA awareness session for frontline teams (WhatsApp, HR, support).
5. Schedule quarterly programme reviews with legal, security, product, and ops.
6. Present a one-page board summary: five risks, five evidence gaps, 90-day plan status.
7. Maintain policy horizon log (Section 22) with monthly scan owner.

4. India anchor box

Anchor	Requirement
Section 8	Data Fiduciary responsibility and overall accountability
Rule 9	Publish contact of DPO or authorised person
Section 10 + Rule 13	Enhanced governance for Significant Data Fiduciaries (if designated)
Sections 18-34	DPBI expects documented compliance in digital proceedings

5. If you know GDPR

GDPR DPO requirements apply to subsets of controllers. India requires a **published contact** broadly via Rule 9; SDFs face heavier duties. Governance maturity matters even for SMEs because processors and customers increasingly audit upstream.

6. Evidence checklist

- ☐ Named programme owner and executive sponsor
- ☐ Published DPO/authorised contact
- ☐ Approved policy set with version dates
- ☐ Training attendance or completion records
- ☐ Quarterly review minutes
- ☐ Board or leadership summary samples
- ☐ Access review records

Section 16: OPERATE Chapter 6 - Third-Party and Vendor Control

Your vendor's mistake is still your customer problem. **Third-party** is vendor governance and cross-border discipline - contracts, audits, and transfer registers so partners do not become your weakest shutter.

Analogy: If you outsource delivery, you still answer when the package is opened en route. Processors are that delivery chain for data.

1. What good looks like

- Processor register with purpose, data shared, and location
- Contracts include DPDPA-aligned security, breach cooperation, deletion, and audit clauses (Rule 6)
- Cross-border transfer register with destination countries and legal watch on **Rule 15**
- Due diligence before onboarding HR, cloud, payment, ad-tech, BGV vendors
- SDF-designated firms extend due diligence to algorithmic tools (Rule 13)
- Government information requests escalated to legal leadership (Rules 23/Schedule 7)

2. Do this now

1. List all processors: cloud, email, CRM, payroll, payments, analytics, support tools.
2. Upgrade contracts with processor obligations and breach notification cooperation.
3. Map cross-border flows (US, EU, Singapore, etc.); monitor MeitY restricted-country notifications.
4. Block vendor access by least privilege; review quarterly.
5. Maintain subprocessors list for critical vendors.
6. Create legal escalation path for government information demands.
7. If SDF-scale, prepare algorithmic due diligence and audit cadence.

3. India anchor box

Anchor	Requirement
Section 8	Data Fiduciary responsible for processor control
Section 16	Government may restrict transfers to notified countries
Rule 6	Processor contract clauses for security measures
Rule 15	Transfer conditions as Central Government may specify
Rule 13	SDF due diligence for algorithms/tools; localisation watch

4. If you know GDPR

GDPR Article 28 processor terms and SCCs are the reference point. India has **no SCC regime** in the same form; instead, watch **government restrictions** and Rule 15 conditions. Map flows now; do not assume GDPR transfer tools alone suffice.

5. Evidence checklist

- [] Processor/vendor register
 - [] Signed contracts with privacy/security clauses
 - [] Cross-border transfer map
 - [] Vendor review or audit trail
 - [] Subprocessor disclosures
 - [] Government request escalation log (if applicable)
-

Section 17: OPERATE Chapter 7 - Event and Breach Readiness

Event covers security incidents and the breach clock - detection, containment, notification, and recovery. Retention and preventive security sit here and in Evidence; this chapter focuses on **what happens when something goes wrong**.

1. Business hook

Trust breaks in two acts: the leak, and the slow response. Event is your immune response - not only firewalls, but rehearsed timelines for users, the Board, and your own team.

Analogy: A shopkeeper locks the shutter at night, throws away expired stock, and calls the police immediately after a break-in. Event is the break-in response playbook.

2. What good looks like

- Documented security baseline: encryption where appropriate, access control, logging, backups, monitoring (Rule 6)
- Retention schedule with deletion workflows and exceptions documented
- Incident response playbook with roles, templates, and timers
- Affected users notified without undue delay; Board notified without undue delay; detailed Board report within **72 hours** (Rule 7)
- One-year log retention for security events where Rule 6 applies
- Large e-commerce/social/gaming entities track Rule 8/Schedule 3 inactivity erasure if applicable

3. Do this now

1. Adopt a minimum security baseline checklist aligned to Rule 6.
2. Map who can access high-care data; remove shared logins and stale accounts.
3. Write retention rules by data type; automate deletion where possible.

- 4. Create breach playbooks: contain, assess, notify users, notify Board, 72-hour report.
- 5. Train frontline staff on "wrong WhatsApp report" and laptop-loss scenarios.
- 6. Test backups and access removal for ex-employees quarterly.
- 7. Run an annual tabletop breach drill and file the record in your evidence pack.

4. Breach response clock

Diagram: see figure below.

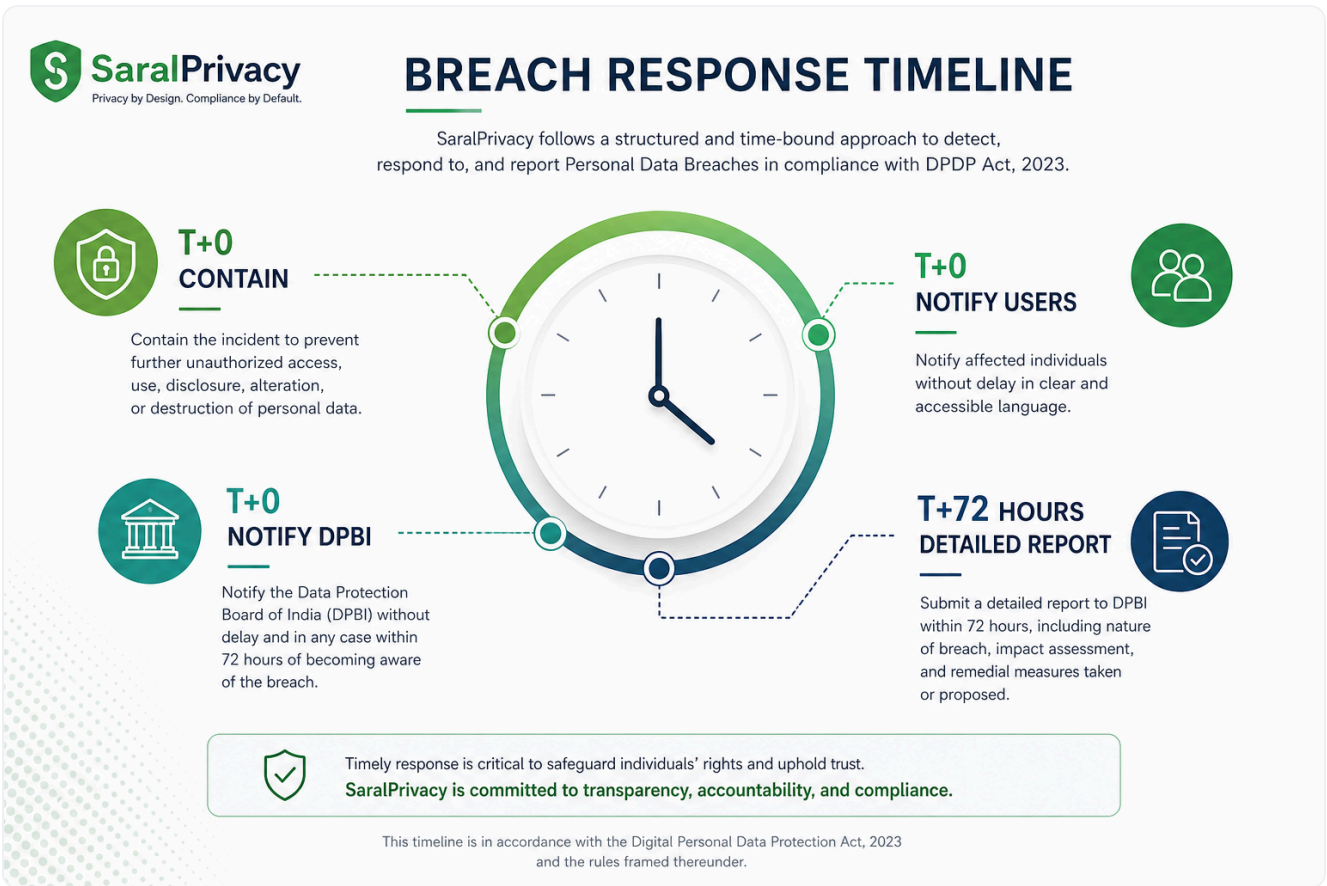


Figure: Infographic 4: Breach Response Clock (PNG export for PDF; Mermaid source in infographics/)

Clock	Action	Evidence to save
Immediate	Contain + assign owner	Timeline, systems affected
Without undue delay	User notice draft	Facts known, remediation offered
Without undue delay	DPBI notification	Initial facts log
72 hours	Detailed report	Full incident record, root cause, fixes

Analogy: Like a fire drill - you do not invent the plan during the fire.

5. India anchor box

Anchor	Requirement
Section 8(5)-(7)	Reasonable security safeguards; breach intimation duties
Rule 6	Encryption/masking, access control, logs, monitoring, backups, processor clauses
Rule 7	User notice without undue delay; Board notice without undue delay; detailed report within 72 hours
Rule 8 + Schedule 3	Erasure after inactivity for specified entities; 48-hour warning; logs

6. If you know GDPR

GDPR Articles 32-33 require security and breach notification. India's Rule 7 sets a **72-hour detailed report** to the Board after notification - treat this as a hard operational SLA, not a "best efforts" email.

7. Evidence checklist

- [] Security baseline document and implementation evidence
- [] Access control matrix and offboarding records
- [] Retention schedule + deletion logs
- [] Incident response plan and tabletop exercise notes
- [] Breach notification templates (user + Board)
- [] Security log retention policy (minimum one year where required)

Section 18: Implementation Kits

These kits translate OPERATE v6.1 into checklists teams can run this month. Score maturity, fix notices, and add children's data and retention where v6 only had partial coverage.

DPDPA READINESS CHECKLIST (MAPPED TO OPERATE V6.1)

Score each row: **0** = not started, **1** = partial, **2** = documented and operating.

#	Control	O	P	E	R	A	T	E
1	Processing activity register	*						
2	Lawful basis tagged per feature		*					
3	Standalone product notice		*					
4	Consent and notice version log			*				
5	Security baseline + access control							*
6	Breach playbook with 72-hour timer			*				*
7	Rights request inbox + owner				*			
8	Named programme owner + board review					*		
9	Processor contracts updated			*			*	
10	Cross-border flow map			*			*	
11	Quarterly horizon review			*		*		
12	Child/minor flow assessment (if applicable)		*	*				

Maturity bands: 0-7 = Ad hoc | 8-14 = Repeatable | 15-20 = Defined | 21-24 = Managed

DATA INVENTORY TEMPLATE (STANDALONE)

Field	Example
Activity name	Customer checkout
Data categories	Name, phone, address, payment ref
Lawful basis	Consent + contract
Source / channel	Website form
Storage location	Shopify + payment gateway (US)
Processors	Shopify, Razorpay, Shiprocket
Retention period	7 years tax; marketing until withdraw

Field	Example
Owner	Head of E-commerce
Last reviewed	14 Jun 2026

NOTICE WRITING KIT (5 BULLETS)

1. **Lead with purpose** - "We collect X to do Y" in the first screen or paragraph.
2. **Itemise data** - phone, email, payment reference, device ID - not "personal information."
3. **Separate optional uses** - marketing, analytics, testimonials on their own lines.
4. **Show rights paths** - access, correction, erasure, grievance, Board complaint with links.
5. **Keep it standalone** - never bury core notice inside Terms and Conditions (Rule 3).

CONSENT FLOW KIT (5 STEPS)

1. **Identify the moment** - checkout, signup, form, WhatsApp opt-in.
2. **Split necessary vs optional** - only optional boxes for optional processing.
3. **Use clear affirmative action** - button or unchecked tick; no pre-ticked marketing.
4. **Log evidence** - what, when, channel, version of notice shown.
5. **Mirror withdrawal** - same channels or easier; confirm withdrawal to user.

VENDOR GOVERNANCE KIT (5 BULLETS)

1. Maintain a **processor register** linked to your data map.
2. Require **security, breach, deletion, and audit** clauses in contracts (Rule 6).
3. Map **data location** and subprocessors for cloud and ad-tech.
4. **Offboard vendors** with access removal and return/deletion certificates.
5. **Review annually** - or when vendor incident news breaks.

BREACH RESPONSE CHECKLIST

1. **Contain** - stop spread, preserve logs, assign incident lead.
2. **Assess** - data types, volume, harm likelihood.
3. **Notify users** without undue delay with facts known and remediation steps.
4. **Notify DPBI** without undue delay; prepare 72-hour detailed report.
5. **Record** timeline, decisions, templates, root cause, and fixes in evidence pack.
6. **Review** access controls and vendor clauses that failed.

CHILDREN'S DATA CHECKLIST

Diagram: see figure below.

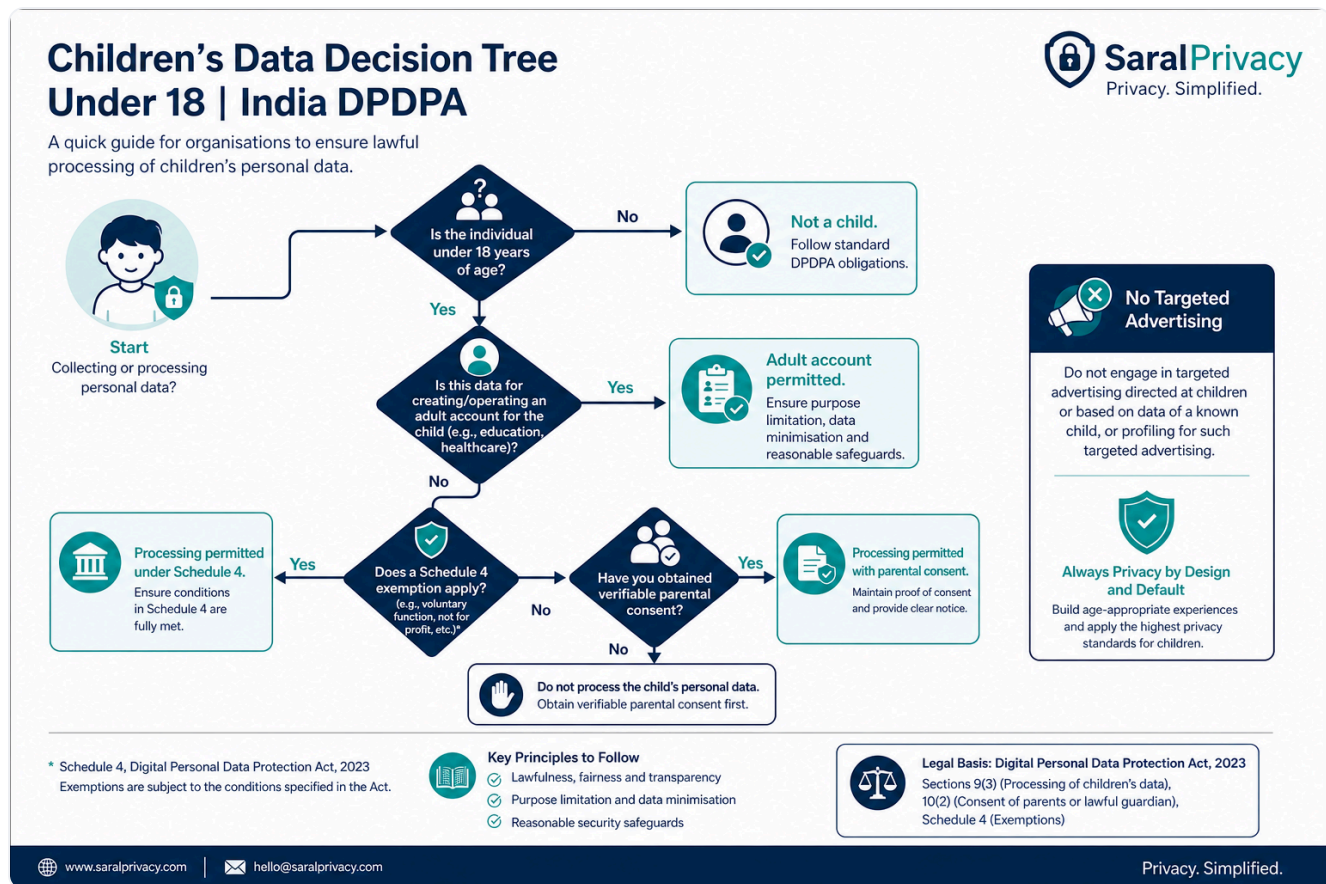


Figure: Infographic 5: Children's Data Decision Tree (PNG export for PDF; Mermaid source in infographics/)

India-specific: Uniform age threshold is **under 18** (stricter than many global laws).

Practical steps:

1. Identify flows where users may be under 18 (education, gaming, family apps).
2. Implement age gate or account type declaration where appropriate.
3. Capture verifiable parental consent before optional processing.
4. Block behavioural ads and tracking on child-directed services.
5. Document Schedule 4 exemptions narrowly if applicable (schools, clinics).

RETENTION CHECKLIST

1. Define retention period per data category tied to purpose (tax, contract, dispute).
2. Document exceptions (legal hold, active grievance, regulatory request).

3. Automate deletion or anonymisation where systems allow.
4. For large e-commerce/social/gaming, assess Schedule 3 inactivity erasure duties.
5. Log deletions and periodic retention reviews in evidence pack.

SDF READINESS PACK (CONDITIONAL)

Apply only if scale, sector sensitivity, or systemic risk makes Significant Data Fiduciary designation plausible:

- Appoint or designate **Data Protection Officer** contact (Rule 9)
- Annual **Data Protection Impact Assessment** and audit (Rule 13)
- Furnish significant audit observations to Board as required
- **Algorithmic due diligence** for tools affecting individuals at scale
- **Localisation watch** for categories Government may specify
- Board-facing evidence pack and executive sponsor
- Enhanced processor and transfer governance

READINESS SCORECARD (10 QUESTIONS MAPPED TO OPERATE V6.1)

#	Question	Domain
1	Can you list every type of personal data you collect in plain English?	Observe
2	Do you know which country each major system stores data in?	Observe
3	Is every use tagged consent or a specific Section 7 ground?	Permission
4	Can users withdraw optional consent as easily as they gave it?	Permission
5	Is notice standalone at each major collection point?	Permission
6	Can you produce consent and notice version logs for a sample user?	Evidence
7	Do you have a breach playbook with a 72-hour Board report step?	Event
8	Can a customer submit a rights request today and get a tracked response?	Rights
9	Do processor contracts require security and breach cooperation?	Third-party
10	Did leadership review DPDPA risk in the last 90 days?	Accountability

Scoring: 8-10 yes = strong runway | 5-7 = gaps to close before 2027 | 0-4 = start with Observe + Permission immediately

Section 19: 12 Industry Risk Snapshots

Full 12-block industry playbooks live on the SaralPrivacy website. This section gives **compact snapshots** for PDF readers - enough to prioritise two flows to fix first (CEO page, Section 4).

RISK HEATMAP

Diagram: see figure below.

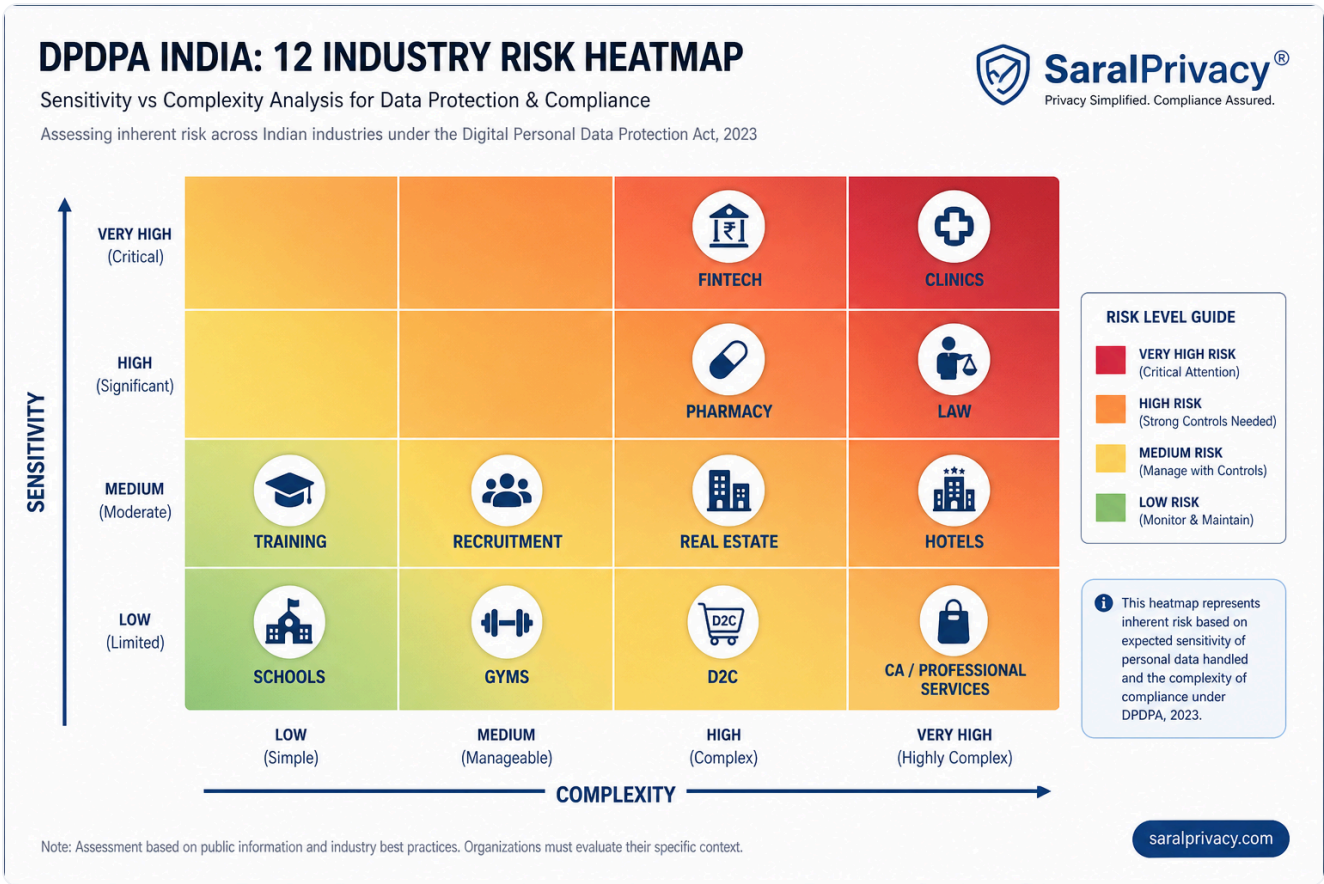


Figure: Infographic 6: Industry Risk Heatmap (PNG export for PDF; Mermaid source in infographics/)

Priority	Industries	Scan route
Critical	Clinics, Schools, Fintech	Sector scan first

Priority	Industries	Scan route
High	CA, Pharmacy, Law, Training	Sector scan + generic assessment
Medium	D2C, Recruitment, Hotels, Real Estate, Gyms	Sector scan when relevant

CA FIRMS

Primary risk theme: Client-document control - not tax knowledge.

Who: Solo CA and partnerships, GST/payroll/advisory firms, teams using article assistants and shared cloud folders.

Common personal data: PAN, Aadhaar, ITR files, bank statements, payroll, Google Drive, WhatsApp, article staff access, old client files

High-risk flows:

1. Clients send PAN and bank statements via WhatsApp or email without standard intake
2. Shared Drive folders with stale access for ex-articles and interns
3. Old ITR and KYC copies retained indefinitely without deletion rules

DPDPA obligations triggered: Notice (R3) | Security (R6) | Breach (R7) | Rights (R14) | Sections 4, 5, 6/7, 8

Immediate actions:

1. Standardise how clients upload PAN, Aadhaar, ITR and bank documents
2. Restrict and review access to Google Drive, email folders and client files
3. Define retention rules for old ITR files, PAN copies, bank statements and payroll data

Scan: saralprivacy.com/assessment/ca-firms - 10 questions - ~3 min

RECRUITMENT AGENCIES

Primary risk theme: CV movement across clients, tools, and teams - not just forwarding resumes.

Who: Recruitment and staffing agencies, executive search, RPO teams sharing CVs via email or portals.

Common personal data: CVs, candidate consent, job portals, LinkedIn, ATS, WhatsApp, client sharing, BGV, salary slips, rejected profiles, AI screening

High-risk flows:

1. Early collection of PAN, Aadhaar, salary slips before offer stage
2. Bulk CV folders shared with clients via WhatsApp or email attachments
3. Rejected candidate profiles kept indefinitely without deletion process

DPDPA obligations triggered: Notice (R3) | Consent (Sec 6) | Security (R6) | Breach (R7) | Rights (R14)

Immediate actions:

1. Standardise candidate sourcing and consent/notice language
2. Reduce early collection of PAN, Aadhaar, salary slips and BGV files
3. Control CV sharing with clients and avoid bulk folders

Scan: sara.privacy.com/assessment/recruitment - 10 questions - ~3 min

TRAINING INSTITUTES

Primary risk theme: Minors, parents, WhatsApp groups, and LMS data - not just classroom delivery.

Who: Coaching centres, test-prep brands, EdTech with live classes and LMS, institutes with parent WhatsApp groups.

Common personal data: Student data, parent details, minors, WhatsApp groups, LMS tools, student photos, testimonials, attendance, fee records, placement data

High-risk flows:

1. Students below 18 without documented parent/guardian consent
2. Photos, testimonials, and demo-class recordings used for marketing without separate consent
3. Old leads and admission records retained without clear rules

DPDPA obligations triggered: Notice (R3) | Children (Sec 9, R10) | Security (R6) | Rights (R14)

Immediate actions:

1. Record whether students are below 18 and capture parent/guardian consent
2. Standardise student and parent data intake away from informal channels
3. Review WhatsApp groups, photos, testimonials and demo-class recordings

Scan: sara.privacy.com/assessment/training-institutes - 10 questions - ~3 min

D2C BRANDS

Primary risk theme: Marketing and ad-tech engine behind every order - not just product sales.

Who: Shopify/Woo D2C brands, beauty/wellness/food lifestyle labels, teams running Meta ads and WhatsApp campaigns.

Common personal data: WhatsApp marketing, Meta Pixel, cart abandonment, Shopify, SMS opt-in, logistics vendors, loyalty, unsubscribe, customer data, marketplace

High-risk flows:

1. Promotional WhatsApp/SMS without provable opt-in
2. Meta Pixel and retargeting without cookie/notice disclosure
3. Logistics and ad vendors receiving customer data without mapped contracts

DPDPA obligations triggered: Notice (R3) | Consent (Sec 6) | Security (R6) | Vendors (R6, R15) | Rights (R14)

Immediate actions:

1. Capture and prove separate opt-in for WhatsApp/SMS/email promotions
2. Disclose Meta Pixel, GA and retargeting tools in privacy/cookie notice
3. Enable unsubscribe and preference management across all channels

Scan: sara.privacy.com/assessment/d2c - 10 questions - ~3 min

CLINICS AND DIAGNOSTIC LABS

Primary risk theme: Health reports, WhatsApp sharing, and access control - highest sensitivity band.

Who: Single and multi-speciality clinics, pathology and radiology labs, home sample collection chains.

Common personal data: Patient reports, prescriptions, health data, WhatsApp sharing, lab software, reception access, home collection, doctor referrals, insurance/TPA, old reports

High-risk flows:

1. Lab reports shared on WhatsApp to patients or family without recipient verification
2. Shared logins or ex-staff access to clinic/HIS systems
3. Outsourced labs and home collection partners without vendor register

DPDPA obligations triggered: Notice (R3) | Security (R6) | Breach (R7) | Rights (R14) | Rule 12/Schedule 4 (child health)

Immediate actions:

1. Standardise patient intake channels - reduce scattered WhatsApp and paper intake

2. Verify recipients before sharing reports by WhatsApp or email
3. Restrict reception, billing, lab and support staff access with role-based controls

Scan: saraalprivacy.com/assessment/clinics-diagnostic-labs - 10 questions - ~3 min

SCHOOLS AND COLLEGES

Primary risk theme: Children's data, CCTV, apps, and transport monitoring - critical priority.

Who: K-12 schools, colleges, institutions with ERP apps, CCTV, transport GPS, and fee systems.

Common personal data: Children's data, parent records, school apps, CCTV, attendance, transport GPS, student photos, fee records, LMS, old student files

High-risk flows:

1. Students below 18 without specific parent notice and consent process
2. Public photos, videos, and results without separate consent
3. CCTV, biometric, RFID, and transport GPS without governance and retention rules

DPDPA obligations triggered: Notice (R3) | Children (Sec 9, R10-12) | Security (R6) | Breach (R7) | Rights (R14)

Immediate actions:

1. Map where student and parent data is collected and stored
2. Strengthen parent/guardian notice and consent for students below 18
3. Govern CCTV, biometric, RFID, transport GPS and hostel monitoring

Scan: saraalprivacy.com/assessment/schools-colleges - 10 questions - ~3 min

LAW FIRMS

Primary risk theme: Matter files, evidence, and junior access - confidentiality plus DPDPA evidence.

Who: Litigation and corporate practices, boutiques, teams with juniors, interns, and matter folders.

Common personal data: Client KYC, PAN/Aadhaar, case files, evidence records, affidavits, WhatsApp instructions, court filing, junior access, external counsel, closed matters

High-risk flows:

1. Sensitive case files on shared drives without matter-team restriction

2. Evidence received via WhatsApp or informal email exports
3. Ex-staff, interns, or associates retaining cloud or device access

DPDPA obligations triggered: Notice (R3) | Security (R6) | Breach (R7) | Rights (R14) | Cross-border (Sec 16)

Immediate actions:

1. Map client documents and matter-data flows
2. Restrict sensitive case files to the matter team
3. Standardise WhatsApp/email/shared-folder usage for client documents

Scan: saraiprivacy.com/assessment/law-firms - 10 questions - ~3 min

REAL ESTATE

Primary risk theme: KYC and broker networks moving property and identity data.

Who: Brokers, property consultants, developer sales desks, rental and resale teams.

Common personal data: Buyer leads, tenant KYC, PAN/Aadhaar, rent agreements, sale deeds, property papers, WhatsApp groups, broker networks, loan partners, old leads

High-risk flows:

1. PAN/Aadhaar/property docs received and forwarded via WhatsApp
2. Lead sheets in broker WhatsApp groups without client notice
3. Ex-staff or old broker partners retaining CRM or cloud access

DPDPA obligations triggered: Notice (R3) | Security (R6) | Breach (R7) | Rights (R14)

Immediate actions:

1. Standardise KYC and property-document collection
2. Reduce WhatsApp forwarding of PAN, Aadhaar and agreement documents
3. Control lead sharing with co-brokers, builders, landlords and loan partners

Scan: saraiprivacy.com/assessment/real-estate - 10 questions - ~3 min

HOTELS AND TRAVEL

Primary risk theme: Guest IDs, passport copies, and OTA data sharing.

Who: Hotels, resorts, homestays, travel agencies, corporate travel desks.

Common personal data: Guest IDs, passport copies, booking history, OTA sharing, travel documents, WhatsApp confirmations, CCTV, PMS access, transport vendors, old guest records

High-risk flows:

1. Passport and visa documents collected through WhatsApp or personal email
2. Foreign guest and C-Form data retained indefinitely
3. Shared PMS/OTA logins and ex-staff access to guest systems

DPDPA obligations triggered: Notice (R3) | Security (R6) | Breach (R7) | Rights (R14) | Cross-border (R15)

Immediate actions:

1. Standardise ID, passport and travel-document collection
2. Reduce WhatsApp/email sharing of guest IDs and passport copies
3. Restrict PMS, CRM, OTA dashboard, CCTV and staff device access

Scan: sara.privacy.com/assessment/hotels-travel - 10 questions - ~3 min

PHARMACIES

Primary risk theme: Prescriptions, medicine history, and refill campaigns.

Who: Retail and chain pharmacies, online pharmacy fulfilment, teams receiving prescriptions on WhatsApp.

Common personal data: Prescriptions, medicine history, WhatsApp orders, refill reminders, delivery partners, billing software, health indicators, staff access, old records

High-risk flows:

1. Prescription images received through WhatsApp or staff phones
2. Refill or promotional messages for sensitive medicine categories without separate consent
3. Shared pharmacy software logins and uncleared ex-staff access

DPDPA obligations triggered: Notice (R3) | Security (R6) | Breach (R7) | Children (R10-12) | Rights (R14)

Immediate actions:

1. Standardise prescription collection and storage
2. Reduce WhatsApp and staff-phone handling of prescription images
3. Define retention and refill-message rules for medicine-history data

Scan: sara.privacy.com/assessment/pharmacies - 10 questions - ~3 min

FINTECH AND NBFC

Primary risk theme: KYC, profiling, DSAs, and cross-border analytics – critical complexity.

Who: NBFCs, digital lenders, payment apps, UPI/wallet/BNPL, collections businesses.

Common personal data: KYC, PAN/Aadhaar, bank data, UPI, credit bureau, profiling, DSAs, collection agents, payment partners, old records

High-risk flows:

1. KYC and bureau data collected via WhatsApp or field agents without consent evidence
2. Automated decisioning with limited customer-facing explanation
3. DSAs and collection agents with download/export access to customer lists

DPDPA obligations triggered: Notice (R3) | Consent (Sec 6) | Security (R6) | Breach (R7) | SDF watch (R13) | Rights (R14) | RBI sector rules

Immediate actions:

1. Map KYC, bank, bureau, UPI and repayment data flows
2. Strengthen timestamped consent for verification, profiling and sharing
3. Control DSA, collection-agent, call-centre and vendor access

Scan: saralprivacy.com/assessment/fintech-nbfc – 10 questions – ~3 min

GYMS, SALONS AND SPAS

Primary risk theme: Health-adjacent body data, photos, and WhatsApp campaigns.

Who: Gyms, fitness studios, salons, spas, wellness chains with membership and appointment apps.

Common personal data: Membership data, health details, body measurements, customer photos, before-after images, WhatsApp campaigns, appointment apps, staff phones, old records

High-risk flows:

1. Customer photos used for social media or ads without separate consent
2. Health and body data recorded on staff phones or WhatsApp
3. Shared CRM or appointment app logins across trainers and therapists

DPDPA obligations triggered: Notice (R3) | Consent (Sec 6) | Security (R6) | Breach (R7) | Rights (R14)

Immediate actions:

1. Map customer data across forms, apps, WhatsApp, DMs and staff notes

2. Capture consent before using customer photos, before-after images or testimonials
3. Restrict access to health, body, consultation and transformation data

Scan: saraalprivacy.com/assessment/gyms-salons-spas - 10 questions - ~3 min

Section 20: Act Section Map

Sec.	Topic	Plain meaning	Action for organisations
3	Application	Digital personal data in India; offline data later digitised; foreign processing tied to offering goods/services in India.	Map customers, employees, vendors, leads, website/app users and India-facing services.
4	Grounds	Processing must be for a lawful purpose and either consent or certain legitimate uses.	Tag every processing activity as consent-based or legitimate-use based.
5	Notice	Notice must tell the Data Principal what data is processed, purpose, rights, withdrawal and complaint route.	Use standalone notices; do not hide core notice inside long T&Cs.
6	Consent	Consent must be free, specific, informed, unconditional and clear affirmative action; withdrawal must be easy.	Separate consent for optional uses such as marketing, profiling, photos, or referrals.
7	Legitimate uses	Limited non-consent grounds such as voluntary data for specified purpose, State functions, legal compliance, court orders, medical emergency, disaster/public order, employment safeguards.	Do not call every business convenience a legitimate use.
8	DF obligations	Data Fiduciary remains responsible for lawful processing, security, breach notice, deletion, grievance, processor control.	Create owner, records, breach process, retention schedule and processor contracts.
9	Children	Verifiable parental consent; no tracking, behavioural monitoring or targeted ads directed at	Classify child-facing flows and stop

Sec.	Topic	Plain meaning	Action for organisations
		children; no harmful processing.	targeted advertising to children.
10	SDF	Extra obligations for notified Significant Data Fiduciaries.	Prepare only if scale/risk/sector makes designation plausible.
11-14	Rights	Access, correction, completion, updating, erasure, grievance, nomination.	Build a request process with identity checks and response ownership.
15	Duties of Data Principal	No impersonation, false complaint, suppression of material information or unverifiable information for correction/erasure.	Publish fair-use language in rights workflow.
16	Cross-border	Government may restrict transfer to notified countries/territories; stricter sectoral laws still apply.	Maintain a cross-border register and monitor notifications.
17	Exemptions	Certain processing for legal rights, courts, prevention/investigation/prosecution, mergers, defaults, State security/public order, research/statistics may be exempted.	Apply exemptions narrowly and document the legal basis.
18-34	DPBI	Digital Data Protection Board, proceedings, orders, mediation, voluntary undertakings, penalties.	Keep evidence because enforcement is digital and document-led.
36-37	Government powers	Government information request powers; blocking recommendation after repeat penalties and non-compliance.	Escalate government notices to legal leadership.
44	Amendments	Amends TDSAT framework, IT Act and RTI Act Section 8(1)(j).	Track pending RTI/privacy litigation before firm public-sector guidance.

Rule	Topic	What the Rule says	Build this control
1-2	Commencement/definitions	Defines commencement, user account, techno-legal measures and verifiable consent.	Use rule definition in policy and product specs.
3	Notice	Notice must be independently understandable, plain, itemised, and provide links for withdrawal, rights and Board complaint.	Separate notice from T&Cs and keep it language-accessible.
4 + Sch. 1	Consent Managers	India-incorporated company, minimum INR 2 crore net worth, interoperable platform, independence, auditability, no misuse.	Only relevant if operating/register as Consent Manager or integrating with one.
5 + Sch. 2	State processing	Standards for State or instrumentalities processing data for subsidy, benefit, service, certificate, licence or permit.	Government-linked projects need Schedule 2 compliance review
6	Security safeguards	Encryption/obfuscation/masking/tokenisation, access control, logs, monitoring, backup, processor contract clauses, organisational measures.	Create minimum security baseline and one-year log retention.
7	Breach notice	Notify affected Data Principals without delay; notify Board without delay; detailed Board report within 72 hours.	Maintain incident clock, facts log, use notice template and Board report template.
8 + Sch. 3	Erasure/retention	Certain large e-commerce, social media and online gaming entities must erase after specified inactivity period; 48-hour warning; logs for at least one year.	Retention schedule plus automated deletion and exception handling
9	Contact point	Publish contact of DPO or authorised person for Data Principal questions.	Put contact in website/app and notices.
10	Child consent	Verify parent/adult using existing reliable details, voluntary identity/age details, or virtual token from authorised entity.	Add age gate and parent verification for child data.

Rule	Topic	What the Rule says	Build this control
11	Persons with disability	Verify lawful guardian under applicable disability laws where required.	Do not assume all disability requires guardian consent.
12 + Sch. 4	Children exemptions	Specified classes such as clinical establishments, mental health establishments, educational institutions, childcare, transport, creches may process for listed purposes.	Use only for listed purpose and class not for advertising or profiling.
13	SDF obligations	Annual DPIA and audit; significant observations furnished to Board; due diligence for algorithmic/tools; possible localisation of specified data.	SDF readiness pack, DPO, DPIA, audit, algorithmic risk review, localisation watch.
14	Rights requests	Publish how Data Principals can make rights and nomination requests; grievance response within maximum 90 days.	Rights SOP, identity verification, queue tracking and closure evidence.
15	Transfer outside India	Transfers must meet requirements the Central Government may specify for availability of personal data to foreign state or controlled entities.	Cross-border register and contract clauses for government access risk.
16	Research/statistics	Research, archiving or statistical processing exempt only if not used for decisions specific to a Data Principal and meets standards.	Separate analytics/research from decisioning.
17-21 + Sch. 5-6	DPBI	Board chair/members, salary, meetings, functioning as digital office and staff.	Prepare evidence of digital filings.
22	Appeals	Appeal to TDSAT digitally with fee and techno-legal measures.	Track appeal timelines and records.

Rule	Topic	What the Rule says	Build this control
23 + Sch. 7	Government info powers	Government may require information for listed purposes and restrict disclosure.	Create legal review workflow for government information requests.

Section 21: Court Cases and Litigation Tracker

Caveat: Pending cases are awareness items only. No court has stayed or struck down the DPDPA as of 14 June 2026.

Case	Status	Why a business reader should care	Anchor use
Justice K.S. Puttaswamy v Union of India, 2017	Final	Privacy is a fundamental right; proportionality test for State action	Constitutional framing only
K.S. Puttaswamy Aadhaar judgment, 2018/2019	Final	ID/KYC minimisation and proportionality	Industry risk context for Aadhaar/PAN-heavy sectors
CPIO, Supreme Court v Subhash Chandra Agarwal, 2019/2020	Final	Privacy vs public interest in RTI; DPDPA amended RTI Section 8(1)(j)	RTI/privacy interface
Venkatesh Nayak v Union of India, W.P.(C) No. 177/2026	Pending	Challenges RTI amendment, State exemptions, surveillance-related provisions	Horizon / legal watch - Act not stayed
The Reporters' Collective Trust and Nitin Sethi v Union of India	Pending/tagged	Press freedom and public-interest reporting	Media and public-sector disclosures
Geeta Seshu/SFLC petition, W.P.(C) No. 275/2026	Pending/tagged	Public vs private data definitions and government powers	Government data handling watch

Case	Status	Why a business reader should care	Anchor use
Anjali Bhardwaj/Amrita Johri and NCPRI-related petitions, 2026	Pending/tagged	Section 44(3) and republication of RTI-sourced personal data	Civil society and research uses
Chandresh Jain v Union of India, Delhi HC	Notice issued Feb 2026	Board structure, State exemptions, blocking powers	Institutional design watch

Section 22: Current Open Items to Track

Use this tracker in monthly governance reviews. Label each row: **in force**, **notified phase**, **proposed**, or **pending litigation**.

Date	Source	What was discussed	Business impact	Treatment
13 Nov 2025	MeitY G.S.R. 846(E)	Rules notified	Starts phased clock	Anchor date for all timelines
14 Nov 2025	PIB	Rules press release	Public confirmation	Cite in status snapshot
17 Nov 2025	MeitY (reported)	Faster enforcement for large/global-compliant firms	May shorten runway	Horizon alert
23 Jan 2026	MeitY stakeholder meeting	Proposal: 18 to 12 month compliance; SDF list fast-track; Rule 8(3) in 90 days post-amendment	May move deadline to 13 Nov 2026	Flag as <i>proposed</i> , <i>not notified</i>
Feb 2026	MeitY	Industry feedback window (reported deadline 4 Feb 2026)	Outcome pending	Update when Gazette publishes
Jun 2026	MeitY Secretary (ET Telecom)	Awaiting industry input on timeline compression	No final call yet	Do not state accelerated date as law

Date	Source	What was discussed	Business impact	Treatment
2026	Karnataka (reported)	Social media ban proposal for under-16	National vs state competence unclear	Note as policy debate, not DPDPA text
Pending	Supreme Court / Delhi HC	Constitutionality, RTI interface, Board structure	Litigation risk	Court table; no "Act struck down" language
Open	MeitY / DPBI	Restricted country list for transfers	Cross-border contract and mapping decisions	Monitor notifications
Open	MeitY / DPBI	SDF designation list and localisation categories	SDF programme scope	Prepare conditionally
Open	DPBI	Consent Manager operational framework	Product and integration roadmap	Watch from Nov 2026 phase
Open	DPBI	Board portal filing procedures in practice	Evidence format for breach and proceedings	Pilot when portal live

Evolve discipline (from v6): Assign a 30-minute monthly scan owner; publish internal "what changed this quarter" memo; refresh breach tabletop twice a year; re-run data inventory after major product or vendor changes.

Section 23: 90-Day DPDPA Action Plan

This plan assumes a mid-market operator with no dedicated privacy team yet. Adjust owners to your org chart. Goal: exit day 90 with a board-ready evidence pack v1, not perfection.

Diagram: see figure below.

90-DAY DPDPA ACTION PLAN ROADMAP

A 4-PHASE JOURNEY TO BUILD, OPERATIONALIZE AND DEMONSTRATE DPDPA COMPLIANCE.

This 90-day roadmap helps organizations systematically achieve DPDPA readiness and build ongoing privacy maturity.



Figure: Infographic 7: 90-Day Roadmap (PNG export for PDF; Mermaid source in [infographics/](#))

Phase	Weeks	Focus	Outputs	Owner
Discover	1-2	Appoint owner; scope systems; start data map	Named DPDPA owner; processing activity register v0.1	CEO + ops lead
Permission	3-4	Fix notices; tag lawful basis; separate marketing consent	Updated notices; consent flow for optional uses	Legal + product
Control	5-8	Vendors, rights inbox, retention, access controls	Processor review log; rights SOP; retention schedule	IT + procurement + HR
Prove	9-12	Breach drill; governance review; executive sign-off	Tabletop breach record; board summary; evidence pack v1	Security + CEO

WEEK-BY-WEEK DETAIL

Weeks 1-2 (Discover): Name accountable owner. List systems: CRM, HRMS, website, WhatsApp Business, cloud drives, payment tools. Draft processing register with top 10 flows. Flag two industry-specific risks from Section 19.

Weeks 3-4 (Permission): Publish standalone notices for website, app, and top offline form. Split marketing consent. Document Section 7 uses for payroll and legal compliance only where counsel agrees. Start consent/version log.

Weeks 5-6 (Control - vendors and rights): Complete processor register. Upgrade top five vendor contracts. Open rights@grievance inbox. Publish rights instructions. Define 60-day internal SLA.

Weeks 7-8 (Control - retention and access): Approve retention schedule. Remove ex-employee and vendor access. Run access review on shared folders and admin panels.

Weeks 9-10 (Prove): Tabletop breach scenario (WhatsApp mis-send or vendor leak). Time the 72-hour report draft. File incident record even for drill.

Weeks 11-12 (Prove): Leadership review against readiness scorecard. One-page board summary: five risks, five evidence items, open law watchlist. Executive sign-off on 90-day plan wave 2.

SUCCESS CRITERIA AT DAY 90

You should be able to answer **yes** to these without hesitation:

- A named owner can present the processing activity register in a 15-minute walkthrough.
- At least three collection points show standalone notices dated within the last 30 days.
- Top five vendors have signed or amended contracts with security and breach clauses, or a documented plan to upgrade them.
- A test rights request was logged, assigned, and closed with a redacted sample in the evidence pack.
- A breach tabletop produced a timeline, draft user notice, and draft Board notification within the exercise window.
- Leadership can explain which industry flows from Section 19 are priority one and two.

If any answer is no, carry that gap into the next 90-day wave rather than declaring readiness. DPDPA programmes compound - each quarter adds evidence depth, not a new project.

Section 24: Disclaimer and SaralPrivacy Product Bridge

DISCLAIMER

This whitepaper is published by SaralPrivacy for **informational and educational purposes only**. It is not legal advice, not a substitute for counsel qualified in Indian law, and not a guarantee of compliance or regulatory outcome. Law, Rules, notifications, and court decisions may change after the status date (14 June 2026). Verify all deadlines, exemptions, and sectoral obligations with your advisors and official Gazette sources before relying on operational decisions. SaralPrivacy accepts no liability for actions taken solely on the basis of this document.

SARALPRIVACY PRODUCT BRIDGE (RESTRAINED)

SaralPrivacy helps Indian operators **discover** what personal data they actually process and **assess** readiness before deep legal spend. This whitepaper is the map; the tools are the compass check.

Step	Route	What it does
1. Discover	saralprivacy.com/discovery	Map which personal-data types your business collects across channels before building full compliance work
2. Assess	saralprivacy.com/assessment	Generic 10-question readiness scan (~3 minutes)
3. Sector scan	Section 19 routes	Industry-specific 10-question snapshot; deeper diagnostic after initial result

How to use this path: Read Sections 3-5 and your industry snapshot. Run Discovery if you cannot list your data types in plain English. Run the generic or sector Assessment to prioritise gaps. Take outputs to counsel and your 90-day plan owner - not the other way around.

No product feature replaces notice, security, breach response, or rights operations required by law. The tools narrow **where to start** so teams spend legal and engineering time on real flows, not generic anxiety.

Suggested sequence for a first-time reader:

- 1. CEO or founder: Sections 3, 4, 5, and 19 (your industry) - 20 minutes.
- 2. Programme owner: Sections 7-18 plus Section 23 - one working session.
- 3. Legal counsel: Sections 8, 9, 20-22 and glossary - validation pass.
- 4. Board packet: Section 4 infographic, Section 9 obligation table, Section 23 gantt, readiness scorecard from Section 18.

This whitepaper will be updated when Gazette notifications change dates or when SaralPrivacy publishes new industry scan versions. Check the status date on the cover before citing deadlines externally.

Publisher note: SaralPrivacy builds discovery and assessment tools for Indian operators. This document is the public reference edition aligned to OPERATE v6.1 and the June 2026 legal status snapshot. Feedback and corrections welcome via SaralPrivacy support channels.

Glossary (25 terms)

Term	Plain English
Data Fiduciary	The organisation that decides why and how personal data is processed - usually your company.
Data Principal	The person whose data is processed - customer, employee, student, patient, etc.
Data Processor	A vendor that processes personal data on your instructions - cloud host, payroll provider, ATS.
Personal data	Any data about an identifiable person - name, phone, PAN, health record, photo.
Processing	Anything done with data: collect, store, use, share, analyse, delete.
Consent	Clear, specific permission given freely with affirmative action; must be easy to withdraw.
Legitimate uses	Narrow Section 7 grounds allowing processing without consent - not a general business exemption.
Notice	Plain-language explanation at collection about data, purpose, rights, and complaints.
Significant Data Fiduciary (SDF)	Large/high-impact fiduciaries notified by Government with extra duties (DPIA, audit, etc.).
Consent Manager	Registered intermediary helping people give, manage, and withdraw consent across services.
DPBI	Digital Data Protection Board of India - the regulator for DPDPA enforcement.
Grievance	A formal complaint by a Data Principal that you must address within 90 days maximum.

Term	Plain English
Nomination	Right of a Data Principal to name someone to exercise rights on their behalf after death/incapacity.
Breach	Security incident exposing personal data - triggers user and Board notification duties.
72-hour report	Detailed breach report to DPBI within 72 hours of Board notification (Rule 7).
Reasonable security safeguards	Encryption, access control, logs, backups, monitoring - Section 8(5) baseline.
Cross-border transfer	Sending or accessing personal data outside India - subject to future restrictions.
Rule 15 conditions	Government-specified requirements for transfers to foreign states or controlled entities.
Processing activity register	Your inventory of what data you process, why, where, and how long.
Purpose limitation	Using data only for the purpose you stated when collecting it.
Data minimisation	Collecting only what you need for the stated purpose.
Retention schedule	Documented rules for how long data is kept and when it is deleted.
Verifiable consent (children)	Parent/guardian consent that can be checked under Rule 10 methods.
Techno-legal measures	Board/digital compliance requirements combining technology and legal process.
Phased commencement	Different Act/Rules sections become enforceable on different Gazette dates.

Source Register

ID	Source	URL
S1	Digital Personal Data Protection Act, 2023, Act No. 22 of 2023, MeitY/Gazette.	https://www.meity.gov.in/static/uploads/2024/02/Digital-Personal-Data-Protection-Act-2023.pdf
S2	Digital Personal Data Protection Rules, 2025, G.S.R. 846(E), Gazette dated 13 Nov 2025.	https://www.meity.gov.in/static/uploads/2025/11/53450e6e5dc0bfa85ebd78686f9cfebfceadcfccbb7790271cd8dd6e0ee8a62136bd.pdf
S3	Enforcement Timeline for the DPDP Act, G.S.R. 843(E), Gazette dated 13 Nov 2025.	https://www.meity.gov.in/static/uploads/2025/11/c56ceae6c383460ca695774280d8be6e3c182a380032d70400316822952baaf6.pdf
S4	Establishment of Data Protection Board of India, G.S.R. 844(E), Gazette dated 13 Nov 2025.	https://www.meity.gov.in/static/uploads/2025/11/cc217843dc3bc37b2b05bcc3ff707592e53e03601955e9ef7952221e04010502.pdf
S5	PIB release: Government notifies DPDP Rules, 14 Nov 2025.	https://www.pib.gov.in/PressReleaselframePage.aspx?PRID=2190014
S6	Supreme Court Observer: Constitutionality of the DPDPA, Venkatesh Nayak v Union of India.	https://www.scobserver.in/cases/constitutionality-of-the-digital-personal-data-p act-2023/amp/

ID	Source	URL
S7	Moneycontrol: Supreme Court refers RTI amendment challenge to larger bench, 19 Feb 2026.	https://www.moneycontrol.com/news/india/supreme-court-refers-data-protection-amendment-of-rti-act-challenge-to-larger-bench-no-question-of-stay-1383023
S8	Medianama: Supreme Court notice in DPDP Act challenge, 13 Mar 2026.	https://www.medianama.com/2026/03/223-supreme-court-dpdp-act-challenge/
S9	LawBeat: Delhi HC notice on DPDP state exemptions and blocking powers, 19 Feb 2026.	https://lawbeat.in/news-updates/delhi-hc-issues-notice-on-plea-against-state-e-blocking-powers-under-dpdp-act-1566615

India's DPDPA Readiness Whitepaper 2026-2027 v6.1 - SaralPrivacy - 14 June 2026 - OPERATE model - Informational structure, not legal advice.

Know your gaps. Fix what matters.

Start with a free 3-minute privacy readiness scan — then take your industry snapshot from Section 19.

[Take free assessment →](#)

SaralPrivacy

DPDPA readiness whitepaper v6.1 · June 2026 · SaralPrivacy Brand Bible v3.0

[@saralprivacy](#) · [saralprivacy.com](#)